

Password Reuse / Default Passwords

It is common for both users and administrators to leave defaults in place. Administrators have to keep track of all the technology, infrastructure, and applications along with the data being accessed. In this case, **the same password** is often used for configuration purposes, and then the password is forgotten to be changed for one interface or another. In addition, many applications that work with authentication mechanisms, basically almost all, often come with **default credentials** after installation. These default credentials may be forgotten to be changed after configuration, especially when it comes to internal applications where the administrators assume that no one else will find them and do not even try to use them.

In addition, easy-to-remember passwords that can be typed quickly instead of typing 15-character long passwords are often used repeatedly because **Single-Sign-On (SSO)** is not always immediately available during initial installation, and configuration in internal networks requires significant changes. When configuring networks, we sometimes work with vast infrastructures (depending on the company's size) that can have many hundreds of interfaces. Often one network device, such as a router, printer, or a firewall, is overlooked, and the **default credentials** are used, or the same **password is reused**.

Credential Stuffing

There are various databases that keep a running list of known default credentials. One of them is the [DefaultCreds-Cheat-Sheet](#). Here is a small excerpt from the entire table of this cheat sheet:

Product/Vendor	Username	Password
Zyxel (ssh)	zyfwp	PrOw!aN_fXp
APC UPS (web)	apc	apc
Weblogic (web)	system	manager
Weblogic (web)	system	manager
Weblogic (web)	weblogic	weblogic1
Weblogic (web)	WEBLOGIC	WEBLOGIC
Weblogic (web)	PUBLIC	PUBLIC
Weblogic (web)	EXAMPLES	EXAMPLES
Weblogic (web)	weblogic	weblogic
Weblogic (web)	system	password
Weblogic (web)	weblogic	welcome(1)
Weblogic (web)	system	welcome(1)
Weblogic (web)	operator	weblogic
Weblogic (web)	operator	password
Weblogic (web)	system	Passw0rd
Weblogic (web)	monitor	password

Kanboard (web)	admin	admin
Vectr (web)	admin	11_ThisIsTheFirstPassword_11
Caldera (web)	admin	admin
Dlink (web)	admin	admin
Dlink (web)	1234	1234
Dlink (web)	root	12345
Dlink (web)	root	root
JioFiber	admin	jiocentrum
GigaFiber	admin	jiocentrum
Kali linux (OS)	kali	kali
F5	admin	admin
F5	root	default
F5	support	
...	...	...

Default credentials can also be found in the product documentation, as they contain the steps necessary to set up the service successfully. Some devices/applications require the user to set up a password at install, but others use a default, weak password. Attacking those services with the default or obtained credentials is called [Credential Stuffing](#). This is a simplified variant of brute-forcing because only composite usernames and the associated passwords are used.

We can imagine that we have found some applications used in the network by our customers. After searching the internet for the default credentials, we can create a new list that separates these composite credentials with a colon (`username:password`). In addition, we can select the passwords and mutate them by our `rules` to increase the probability of hits.

Credential Stuffing - Hydra Syntax

Password Reuse / Default Passwords

```
dbcypn@htb[/htb]$ hydra -C <user_pass.list> <protocol>://<IP>
```

Credential Stuffing - Hydra

Password Reuse / Default Passwords

```
dbcypn@htb[/htb]$ hydra -C user_pass.list ssh://10.129.42.197
```

...

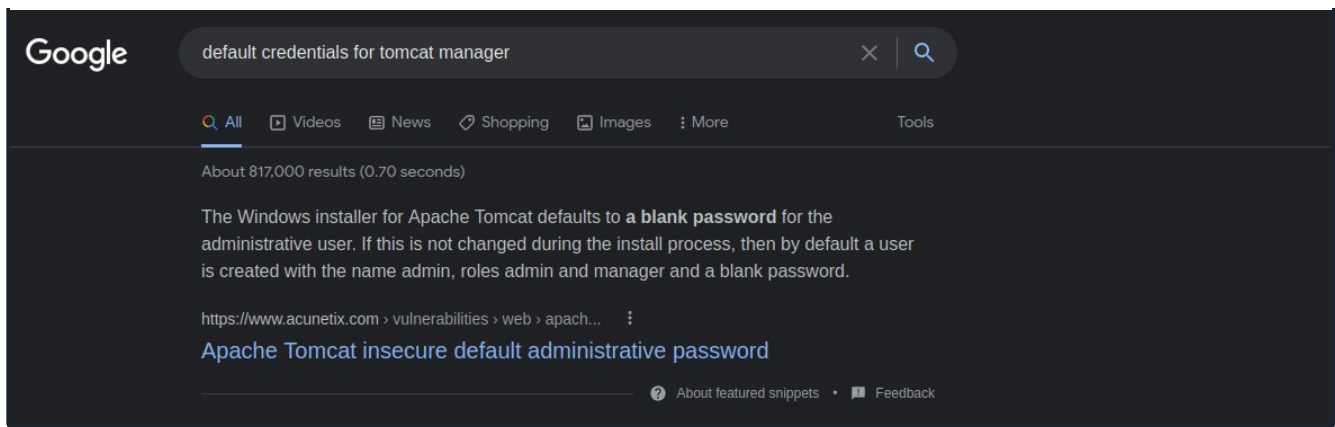
Here, OSINT plays another significant role. Because OSINT gives us a "feel" for how the company and its infrastructure are structured, we will understand which passwords and user names we can combine. We can then store these in our lists and use them afterward. In addition, we can use Google to see if the applications we find have hardcoded credentials that can be used.

Google Search - Default Credentials



https://www.google.com





Besides the default credentials for applications, some lists offer them for routers. One of these lists can be found [here](#). It is much less likely that the default credentials for routers are left unchanged. Since these are the central interfaces for networks, administrators typically pay much closer attention to hardening them. Nevertheless, it is still possible that a router is overlooked or is currently only being used in the internal network for test purposes, which we can then exploit for further attacks.

Router Brand	Default IP Address	Default Username	Default Password
3Com	http://192.168.1.1	admin	Admin
Belkin	http://192.168.2.1	admin	admin
BenQ	http://192.168.1.1	admin	Admin
D-Link	http://192.168.0.1	admin	Admin
Digicom	http://192.168.1.254	admin	Michelangelo
Linksys	http://192.168.1.1	admin	Admin
Netgear	http://192.168.0.1	admin	password
...	...	...	...

VPN Servers

Warning: Each time you "Switch", your connection keys are regenerated and you must re-download your VPN connection file.

All VM instances associated with the old VPN Server will be terminated when switching to a new VPN server.

Existing PwnBox instances will automatically switch to the new VPN server.

us-academy-1

PROTOCOL

☒ UDP 1337 ☐ TCP 443

DOWNLOAD VPN CONNECTION FILE

[Start Instance](#)

∞ / 1 spawns left

Waiting to start...



Questions

Answer the question(s) below to complete this Section and earn cubes!

Target: [Click here to spawn the target system!](#)

[Cheat Sheet](#)[Download VPN
Connection File](#)

+ 0

Use the user's credentials we found in the previous section and find out the credentials for MySQL. Submit the credentials as the answer. (Format: <username>:<password>)

+10 Streak pts

[Submit](#)[Show Solution](#)[← Previous](#)[Next →](#)[Cheat Sheet](#)[Resources](#)[Go to Questions](#)

Table of Contents

Introduction

[Theory of Protection](#)[Credential Storage](#)[John The Ripper](#)

Remote Password Attacks

[Network Services](#)[Password Mutations](#)[Password Policy / Default Passwords](#)

[password reuse / Default Passwords](#)

Windows Local Password Attacks

- Attacking SAM
- Attacking LSASS
- Attacking Active Directory & NTDS.dit
- Credential Hunting in Windows

Linux Local Password Attacks

- Credential Hunting in Linux
- Passwd, Shadow & Opasswd

Windows Lateral Movement

- Pass the Hash (PtH)
- Pass the Ticket (PtT) from Windows
- Pass the Ticket (PtT) from Linux

Cracking Files

- Protected Files
- Protected Archives

Password Management

Password Policies

Password Managers

Skills Assessment

- Password Attacks Lab - Easy
- Password Attacks Lab - Medium
- Password Attacks Lab - Hard

My Workstation

OFFLINE

▶ Start Instance

∞ / 1 spawns left